

Manual Test Checklist

ECITY — Mobile Shop Management Web App

Version 1.1 · 5 September 2026

M0 Foundations · M1 Master Data

One section per module; M2–M14 append as they ship

How to Use This

Automated tests cover the mechanics — 51 unit and integration tests, 91 browser tests across four screen sizes. This checklist covers what a person still has to judge: does it *feel* right, does the wording make sense, does the shop's actual workflow survive contact with the screen.

Work through a module's section after it is built, and again before go-live. Tick as you go. Anything that fails is a bug, not a note.

One section per module. M1–M14 append to this file as they ship.

Before you start

```
docker compose up -d      # or open Postgres.app
npm run db:migrate
npm run db:seed           # resets the three test accounts
npm run dev               # http://localhost:3000
```

To return to a known-clean state at any point, re-run `npm run db:seed`. It upserts, so it is safe to repeat.

Test accounts

Email	Password	Role	Branch scope
admin@ecity.local	ChangeMe!2026	Admin / Owner	All branches (14 permissions)
manager@ecity.local	ChangeMe!2026	Branch Manager	MAIN only (7 permissions)
staff@ecity.local	ChangeMe!2026	Staff	MAIN only (3 permissions)

Use a **private/incognito window** to hold a second session, so you can be two users at once without signing out.

These accounts must never exist in production. They are flagged `mustChangePassword` and are created only by the seed.

M0 — Foundations

Delivers. PRD FR-1.1 – FR-1.5, FR-31.1, plus branch context and the authorisation layer everything else depends on.

Signing in as the admin exercises perhaps a tenth of this module. The interesting part is what the *other two* users cannot do.

1. Authentication

Start signed out, at `/login`.

- [] Wrong password for a real account → *"Email or password is incorrect."*
- [] A made-up email with any password → **the identical message**. It must not reveal whether the account exists
- [] Empty email or password → inline validation, no request sent
- [] Visit `/settings/users` directly while signed out → redirected to `/login`
- [] Correct credentials → lands on `/dashboard`
- [] Avatar menu → **Sign out** → back at `/login`

- [] After signing out, the browser Back button does **not** restore the app
- [] Sign in again in a second browser → both sessions work independently

Password reset

Email is not wired up until M14, so the reset link is shown on screen in development.

- [] `/forgot-password` → enter `admin@ecity.local` → confirmation appears
- [] A **yellow development box** shows the reset link
- [] Enter an address that does not exist → **the same confirmation**, no hint that the account is unknown
- [] Follow the link, set a new password → redirected to `/login`
- [] The **old** password no longer works
- [] The **new** password works
- [] Open the same reset link a second time → refused as already used
- [] Reset the password back to `ChangeMe!2026`, or re-run `npm run db:seed`

Lockout

- [] Get the password wrong 8 times in a row → *"Too many failed attempts."*
- [] Wait 15 minutes, or `npm run db:seed`, to clear it

2. Branch scoping

The heart of M0. Sign in as each user and open the branch switcher in the header.

- [] **admin** — sees *All branches (consolidated)*, MAIN and NORTH
- [] **manager** — sees **MAIN only**. No NORTH, and no "All branches"
- [] **staff** — sees MAIN only
- [] As admin, switch between branches → the dashboard's *Branch context* card updates (active branch, accessible count, consolidated yes/no)
- [] The chosen branch survives a page reload
- [] On a phone-width window the switcher shows the branch **code**, not the full name, and the header still fits

3. Permissions

Check what is **missing**, not what is present.

User	Sidebar should show
admin	Dashboard, Users, Roles, Audit log
manager	Dashboard, Users, Audit log — no Roles
staff	Dashboard only

- [] Each user's sidebar matches the table
- [] As **staff**, type `/settings/roles` into the address bar → redirected, not shown
- [] As **staff**, type `/settings/users` → redirected

- [] As **manager**, `/settings/roles` → redirected
- [] The dashboard's *Your permissions* card lists 14 / 7 / 3 entries respectively

4. Server-side authorisation

A hidden menu item is not a control. This step proves the server refuses the request, not just that the button was hidden.

Sign in as **staff** in the browser, then copy the session cookie from DevTools → Application → Cookies → `ecity_session`, and run:

```
COOKIE='ecity_session=PASTE_VALUE_HERE'
curl -s -o /dev/null -w '%{http_code}\n' localhost:3000/api/users -H "Cookie: $COOKIE"
curl -s -o /dev/null -w '%{http_code}\n' localhost:3000/api/audit -H "Cookie: $COOKIE"
curl -s -o /dev/null -w '%{http_code}\n' localhost:3000/api/roles -H "Cookie: $COOKIE"
```

- [] All three return **403**, not data
- [] The body reads `{"error":"...", "code":"FORBIDDEN"}`
- [] With no cookie at all → **401**
- [] As **manager**, forcing another branch is refused:

```
curl -s -o /dev/null -w '%{http_code}\n' -X POST localhost:3000/api/session/branch \
-H "Cookie: $COOKIE" -H 'content-type: application/json' -d '{"branchId":2}'
```

- [] Returns **403** — branch NORTH is not theirs
- [] `{"branchId":null}` (the consolidated view) also returns **403**

5. User management

As **admin**, Users → Add user.

- [] Password under 10 characters → rejected inline
- [] An email that already exists → *"A user with this email already exists."*
- [] No role chosen → *"Choose a role."*
- [] Create a Staff user assigned to **NORTH** only
- [] They appear in the user list with the right role and branch badge
- [] Sign in as the new user → branch switcher shows **NORTH only**
- [] Their first sign-in is flagged "must change password"

Roles

As **admin**, Settings → Roles.

- [] Select **Staff**, tick *View the audit log*, Save
- [] Sign in as staff → **Audit log now appears** in their sidebar
- [] Any staff session open elsewhere was **signed out** when the role changed, rather than keeping stale permissions until next login
- [] Untick it and Save again
- [] Try to remove *Create and edit users* from **Admin** → refused, so the business cannot lock itself out
- [] System roles cannot be deleted

6. Audit log

As **admin**, Settings → Audit log.

- [] Everything done above appears: **LOGIN**, **LOGIN_FAILED**, **LOGOUT**, **CREATE**, **PERMISSION_CHANGED**, **PASSWORD_RESET_COMPLETED**
- [] Each row shows who, what, when
- [] Expanding a "*n field(s)*" row shows old → new values
- [] A password hash **never** appears in a changes payload
- [] Paging works if there are more than 50 entries

The log is append-only, enforced by the database rather than by code:

```
psql ecity -c "update audit_log set summary='tampered' where id=1;"
psql ecity -c "delete from audit_log where id=1;"
```

- [] Both fail with `audit_log is append-only`

7. Responsive layout

Resize the window, or use DevTools device mode. Check at ~375px, ~810px and full width.

- [] Below ~768px the sidebar is replaced by a **hamburger** top-left
- [] Tapping it opens a drawer; choosing a destination closes it
- [] On **Users**, the table becomes **one card per user**
- [] On **Audit log**, entries become cards
- [] Nothing scrolls sideways at any width
- [] Buttons and links are comfortably tappable with a thumb
- [] The **Roles** editor is usable — role list becomes a horizontal strip
- [] Forms stack, with full-width buttons

8. Theme

- [] Primary colour is **black** throughout (buttons, active nav item)
- [] Set `APP_THEME=navy` in `.env`, restart → the whole app is blue, with no other visual change
- [] An invalid value such as `APP_THEME=nonsense` → falls back to black rather than breaking
- [] Set it back to `onyx`

What M0 deliberately does not include

Do not raise these as bugs:

- No products, inventory, IMEIs, customers or suppliers — those are M1 and M2
- The dashboard shows branch context and permissions, **not** sales figures. The real dashboard is M10
- No branch create/edit screen — M1. The two seeded branches are fixed
- Password reset emails print to screen instead of sending — M14

- Notifications, reports, exports — later modules

M1 — Master Data

Delivers. PRD FR-2.1 – FR-2.4, FR-3.1, FR-3.2, FR-3.8, FR-5.10, FR-6.6, FR-10.1.

The shop gets configured and the people it trades with exist. Nothing here moves stock or money yet — these are the pickers and directories the rest of the system draws on.

Customer = someone who buys from the shop. **Supplier** = someone the shop buys from. Both are shared across every branch.

1. Business settings

Sign in as **admin**, go to **Settings** → **Business**.

- ☐ Four tabs: Profile, Tax, Payments, Expenses
- ☐ On a phone the tabs scroll sideways rather than wrapping

Profile

- ☐ Edit the business name, save, reload — the change persisted
- ☐ Enter a malformed GST number → *"Enter a valid 15-character GSTIN."*
- ☐ Enter a valid one (29ABCDE1234F1Z5) → accepted, stored upper-case
- ☐ Currency is fixed at INR and cannot be edited
- ☐ Toggle **Prices include tax** → the explanation below it changes
- ☐ Save, reload → the toggle held its new position

Tax

- ☐ Five GST slabs are listed: 0, 5, 12, 18, 28%
- ☐ **GST 18%** is marked Default
- ☐ Rates display as 18.00%
- ☐ Add a rate named GST 3% at 3 → appears in the list
- ☐ Add one with the same name → refused as a duplicate
- ☐ Deactivate a non-default rate → shows Inactive
- ☐ Try to deactivate the **default** rate → refused, with the reason

Payments

- ☐ Cash, UPI, Card, Bank Transfer are listed with their type badge
- ☐ Cash carries a **Cash drawer** badge; the others do not
- ☐ Deactivate UPI → shows Inactive; reactivate it
- ☐ Try to deactivate **Cash** → refused: at least one cash method must stay active

Expenses

- ☐ Seven categories: Rent, Electricity, Salaries, Transport, Packaging, Repairs, Miscellaneous
- ☐ Add one → appears immediately

- [] Add the same name again → refused

2. Branches

Settings → **Branches** as admin.

- [] MAIN and NORTH are listed with manager and user counts
- [] **Add branch** — code **MGROAD**, name **MG Road** → created and listed
- [] The code is forced to upper case even if typed lower
- [] Add another with code **MGROAD** → *"Branch code MGROAD is already in use."*
- [] A code containing a space or ! is rejected inline
- [] Open the new branch, change its name, save → the list shows the new name
- [] Assign a manager from the dropdown → shows in the Manager column
- [] Leave the manager empty → **saves without error** (*this failed silently before — see §5*)

Deactivation — the rule that matters (FR-3.8)

- [] Deactivate **MG Road** → badge turns Inactive, **the row stays**
- [] Open the header **branch switcher** → MG Road is **gone**
- [] Reactivate it → it comes back in the switcher
- [] Deactivate every branch but one, then try the last → refused: at least one branch must stay active

3. Customers and suppliers

Customers in the sidebar.

- [] The list is empty, or holds only what you have created
- [] **Add customer** with a name only → saves. A walk-in has nothing else
- [] Add one with phone **9876543210**
- [] Add a second with the **same phone** → *"Another customer (...) already uses this phone number."*
- [] Give a **supplier** that same phone → **allowed**, they are different directories
- [] Edit a customer, keep their phone unchanged, save → no false duplicate
- [] Enter **not-a-phone** → rejected inline
- [] Enter **MiXeDqExample.COM** → stored lower-case (check in Studio)

Search and status

- [] Search by part of a name → matches
- [] Search by phone → matches
- [] Search by email → matches
- [] Search by GST number → matches
- [] **Deactivate** a customer → disappears from the default list
- [] Click **Show inactive** → they reappear, badged Inactive
- [] Reactivate → back to normal

Repeat the same pass on **Suppliers**. Suppliers additionally have a **Company** field; customers do not.

4. Permissions

User	Should see in the sidebar
admin	Customers, Suppliers, Business, Branches, Users, Roles, Audit log
manager	Customers, Suppliers, Business, Users, Audit log — no Branches, no Roles
staff	Customers, Suppliers — no Settings group at all

- [] Each user's sidebar matches
- [] As **staff**, open </settings/business> directly → redirected
- [] As **staff**, open </settings/branches> directly → redirected
- [] As **staff**, open </customers/new> directly → redirected (they may view customers, not create them)
- [] As **manager**, </settings/branches> → redirected. Managers run a branch; they do not create them

At the API, signed in as staff (see M0 §4 for how to get the cookie):

```
curl -s -o /dev/null -w '%{http_code}\n' localhost:3000/api/branches?manage=1 \
-H "Cookie: $COOKIE"
curl -s -o /dev/null -w '%{http_code}\n' -X POST localhost:3000/api/customers \
-H "Cookie: $COOKIE" -H 'content-type: application/json' -d '{"name":"Sneaky"}'
```

- [] The POST returns **403**

5. Form errors are never silent

A bug found during M1: a validation failure with no visible message meant the Save button appeared to do nothing.

- [] Paste 300 characters into any address field → a visible error appears
- [] On every form, an invalid field shows red text under **that** field
- [] No form ever fails with the button simply doing nothing

6. Audit

Settings → **Audit log** as admin.

- [] Everything above is recorded: branch created, customer created, tax rate added, payment method deactivated
- [] Entity types include [branch](#), [customer](#), [supplier](#), [tax_rate](#), [payment_method](#), [business](#)
- [] Expanding a row shows old → new values

7. Responsive

At ~375px, ~810px and full width:

- [] Customers, Suppliers and Branches lists become **cards** below 768px
- [] Business settings tabs scroll rather than wrap
- [] Forms stack to one column; buttons go full width

- [] Nothing scrolls sideways
- [] The sidebar's **Master data** and **Settings** groups appear in the mobile drawer

What M1 deliberately does not include

- **No customer/supplier history tab yet.** Clicking a customer opens the edit form. The profile view showing their purchases, returns and credit arrives with M4/M5, when there is something to show. *This is a known gap against M1's stated criteria, carried into M2.*
- No products, stock or IMEs — that is M2
- Attachments have a working API and storage layer, but **no upload button on any screen yet**; the first screen that needs one is M3's purchase form
- Logo upload is not wired to the business profile

Housekeeping

The end-to-end tests create real branches and customers in your development database. After a test run you will see extra rows. To get back to a clean state:

```
dropdb ecity && createdb ecity
psql -d ecity -c "CREATE ROLE ecity WITH LOGIN PASSWORD 'ecity' SUPERUSER;"
npm run db:migrate && npm run db:seed
```

Sign-off

Tested by	
Date	
Build / commit	
Result	pass / fail
Issues raised	